LEAD ASPIRE • 02 STRATEGIZE

STATEMENT OF WORK

Executive Project Proposal • Prepared for Managing Director Review

Project LaunchGate: policy-aware deployment control plane
Team Garden State (Microsoft Cloud & AI Specialist team)
Customer Mastercard **Consulting partner** EY
Version / Date v1.0 • 12 October 2026

MICROSOFT STACK **Azure AI Foundry** **Azure OpenAI** **Azure Functions** **Azure Policy** **Defender for Cloud** **Azure Deployment Environments** **Entra ID** **Microsoft Teams** **GitHub Copilot** **GitHub Actions** **Azure Cosmos DB** **Microsoft Fabric**

[E] what Mastercard said in Discovery (paraphrased) [H] our hypothesis [?] unknown, must be checked

01 Executive Summary

In Discovery, Maria (Business Development, Mastercard) told us that getting a new cloud environment, "just to create a virtual machine", takes about six to eight months and about twelve handoffs. The ideal state is one. The fix is "not just deployment": it is policy, orchestration and human review. Guardrails cannot be bypassed. Mastercard also expects to add cloud capacity within six months, so the same slow chain would be repeated on a new platform.

We propose LaunchGate, a control plane on Azure that knows the rules. An engineer files one request instead of running twelve handoffs. Agents on Azure AI Foundry build the evidence pack: the completed request, a Bicep template drafted with GitHub Copilot, and a short risk memo. A rule engine built on the Azure Policy schema checks the request and names any rule it fails. The people who must approve get a card in Microsoft Teams with the evidence attached. A GitHub environment protection rule blocks execution until they approve. Every step is logged and shown on a Microsoft Fabric dashboard. Agents prepare, people approve, nothing deploys without a human.

This helps Mastercard engineers who wait to build and reviewers who repeat the same checks. Maria's test is "saving money", and this saves time and effort rather than making revenue. We ask the MD to approve the problem framing, this direction, the prototype scope and permission to proceed to Build.

02 Business Problem & Opportunity

Problem. To get a new cloud environment, Mastercard teams go through a long chain of manual handoffs. Each handoff re-checks compliance by hand. Maria reported 6–8 months and about 12 handoffs, covering "policy and orchestration", not just infrastructure code. The steps live in people's heads, so the process restarts when someone leaves. We read 6–8 months as the whole readiness cycle, not the time to create one VM [?].

Opportunity size. Discovery gave two numbers from the customer (6–8 months, ~12 handoffs) and no volume or cost [?]. As an illustration only: at 10 requests a year, Mastercard waits 60–80 request-months; at 50, 300–400 [H]. We also heard repeat reviewer effort, lost knowledge when staff leave, and a cloud expansion that would inherit the same chain. The prototype produces the measurements that replace these assumptions.

03 Discovery Evidence

- "Just to create a virtual machine … currently takes like 6 to 8 months." "Around 12 handoffs"; ideal state is one. [E]
- "Deployment is not enough. It also includes policy and orchestration." "Security guardrails: we can't come up with an idea and just ship it out." [E]
- "Human review is also important." "Redo the whole process if someone leaves the company." [E]
- Asked if one button to start development was the dream: yes, "a button to just jump onto the development stage." "In the next six months … go onto AWS." [E]
- "Are you making money or saving money? Pick one. Tedious but saves a lot is worth it." Partners ask "how long will it take to implement." [E]
- **Insight:** the long cycle, many handoffs, repeat work and lost knowledge share one cause: there is no single workflow that joins infrastructure code, policy and approvals. [H]

04 Customer Readiness & Strategic Alignment

What we heard about mindset. High appetite for change: Maria volunteered the "button" and the 12-to-1 target. Automation is welcome; bypassing guardrails is not. Human review is required. Risk tolerance is low for production and open for a faster development stage. There are many external compliance processes; which ones are regulatory is unknown [?]. Maria named AWS as a near-term target; Mastercard publicly runs internal workloads on both AWS and Azure. The value lens is saving money.

How the proposal reflects it. We automate the preparation and never the approval: rules decide, humans authorize, AI prepares and explains. We build on Azure, where Azure Policy and Azure Deployment Environments make a governed path native; Defender for Cloud can apply the same standards to AWS accounts, so Mastercard need not choose between speed and guardrails. Development environments only; provisioning simulated; rules illustrative and cited to public standards.

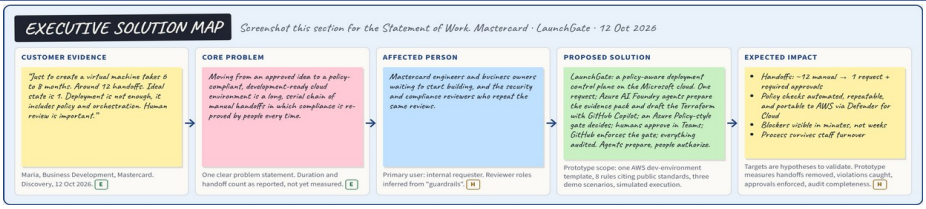
05 Proposed Solution

LaunchGate turns an environment request into a governed, visible, auditable path to "ready to build". Engineers file one request, see at once which rule they failed and why, and get the infrastructure code drafted for them. Reviewers see only requests that passed the automated checks, with the evidence pack attached, and approve from Teams in parallel. The process lives in the platform, not in a person.

- **Evidence is built when the request is filed, not reviewed later.** An agent on Azure AI Foundry writes the risk memo and explains any failed rule. In a pilot this grows to three agents (intake, infrastructure code, risk memo).
- **Rules are code.** Each rule uses the Azure Policy definition schema and cites a public control (PCI DSS 4.0.1, CIS Azure Foundations, NIST SP 800-53). Microsoft Defender for Cloud carries the same standards and can also assess AWS accounts.
- **Approvals where people already work.** Roles come from Microsoft Entra ID. A requester can never approve their own request. Pilot: adaptive cards in Microsoft Teams.
- **Copilot writes the code, GitHub enforces the gate.** GitHub Copilot builds the prototype and drafts the Bicep template. Pilot: the template ships as a pull request, GitHub Advanced Security scans it, and a GitHub Actions environment protection rule blocks deployment until named approvers sign off.

- **The saving is measured, not claimed.** The prototype counts handoffs and wait per gate in-app. Pilot: Microsoft Fabric dashboard, and a Policy Copilot that drafts new rules from a policy document for security to review.

06 Executive Solution Map



Impact targets are hypotheses. The prototype measures handoffs removed, violations caught, approvals enforced and audit completeness.

07 Scope & Deliverables

IN SCOPE FOR THE 2H30 BUILD (P0) AND IF TIME REMAINS (S)

- P0 Portal with one template: Azure development environment for an internal service (Azure Static Web Apps, generated with GitHub Copilot).
- P0 Rule engine with 8 illustrative rules in the Azure Policy schema, each citing a public control ID; every result names the rule.
- P0 Approvals by Entra ID role (security, platform), no self-approval; append-only audit log and status page (Azure Cosmos DB).
- P0 One Azure AI Foundry agent: risk memo for approvers and read-only "why am I blocked?" explainer, grounded on rule results.
- P0 Simulated Azure deployment from a Copilot-drafted Bicep template; handoff and wait-time counters in-app.
- P0 Three scripted scenarios (compliant, blocked, approved and deployed), demo script, measured results.
- S Teams approval card; Bicep pull request behind a GitHub environment protection rule.

OUT OF SCOPE FOR THE PROTOTYPE (PILOT PATH IN SECTION 11)

- Real Mastercard data, policies, credentials or systems; real provisioning on any cloud; production of any kind.
- Automatic approval or deployment by AI; the agent never changes state.
- Mastercard's actual policy catalogue; our rules are stand-ins to be replaced in a pilot.
- Integration with Mastercard ticketing, identity or CI/CD (unknown today); change-advisory and attestation processes.
- Fabric dashboard, Policy Copilot, Azure Deployment Environments, Defender for Cloud multicloud: pilot, not prototype.

08 / 09 Stakeholders, Team & Microsoft Resourcing

Customer. Problem owner: Maria, Business Development. Users: engineers and business owners who request environments. Reviewers: security, compliance and platform teams [H]. Affected: partner clients waiting on delivery. Owners of the 12 handoffs: unknown [?]. **Approvers.** EY Managing Director (this SOW); a Mastercard sponsor to be named; Microsoft Data & AI Technical Specialist; the pitch panel.

ROLE	ORGANIZATION	RESPONSIBILITY	INVOLVEMENT
Engagement lead	Garden State	Discovery synthesis, SOW, EY review, pitch, demo script	Full day
Cloud solution architect and AI specialist	Garden State	Architecture, rule engine and schema, audit model, simulated deployment; Azure AI Foundry agents, explainer, grounding and safety	Full day
App-DevOps and data-governance specialists	Garden State	Portal, approvals, Copilot-drafted Bicep PR, GitHub gate, Teams card; rule-to-control mapping, readiness metrics, Fabric dashboard, security section	Full day
Data & AI Technical Specialist; Copilot support	Microsoft; GitHub	Architecture review, Azure AI Foundry and Defender for Cloud guidance; Copilot and environment-rule guidance	2 × 15 min; 1 × 10 min
Consulting partner and Managing Director; Maria	EY; Mastercard	SOW review and approval; confirm the 6–8 month scope, handoff owners, target cloud and pilot sponsor	2 × 15 min; 1 × 10 min

10 Expected Value & Impact

Prototype shows: about 12 manual handoffs become one request plus the human approvals the rules require; checks run the same way every time, in seconds, and name the rule; blockers and owners are always visible; every decision is logged. **Assumptions:** most of the 6–8 months is waiting between handoffs; many handoffs can become rule checks [H]; request volume justifies a pilot [?]. A saving-money proposal, by Maria's own test.

SUCCESS MEASURE	TARGET / SIGNAL	HOW WE SHOW IT
Manual handoffs from request to ready	Baseline ~12 reported; demo: 1 request + ≤2 human approvals	Count transitions in the audit log
Rule coverage, consistency, blocking	8 rules, all evaluated; same input gives same result; 3 of 3 scenarios behave as specified	Rule results per request; run twice; live demo
Human authority and audit completeness	0 approvals or deployments by AI; 100% of transitions logged; request to approval plan under 2 minutes	Role model, exported audit log, timestamps

SUCCESS MEASURE	TARGET / SIGNAL	HOW WE SHOW IT
Customer validation	A Mastercard or EY reviewer confirms the framing and would sponsor a pilot	Pitch Q&A

11 Long-Term Impact & Potential

90-day pilot. Load Mastercard's real rule catalogue into the same schema (Policy Copilot drafts, security approves). Approvals move to Microsoft Teams with Entra ID Governance access packages. Provisioning runs for real through Azure Deployment Environments from a governed Bicep/Terraform catalog. Microsoft Defender for Cloud scores every environment against PCI DSS 4 and NIST 800-53, including any AWS accounts. A Microsoft Fabric dashboard reports cycle time and handoffs per request. **Target in pilot:** 12 handoffs → 1 request plus required approvals; readiness cycle from months to days for standard environments [H].

12 Microsoft & GitHub Tooling

PRODUCT	WHAT IT DOES IN LAUNCHGATE	WHEN
GitHub Copilot: agent mode in VS Code, coding agent, code review, custom instructions	Builds the prototype: coding agent scaffolds the repo from an issue; agent mode with the Azure MCP server wires Azure resources; Copilot code review checks every PR; instructions encode the rule schema	Build
Azure AI Foundry Agent Service + Azure OpenAI	Risk-memo and explainer agent with read-only tools; three-agent crew in pilot	P0
Azure Functions (Durable Functions) + Azure Cosmos DB + Azure Static Web Apps	Workflow request → validate → prepare → approve → execute → audit; append-only audit store; portal	P0
Azure Policy schema + Microsoft Defender for Cloud	Rule format for the engine; regulatory standards (PCI DSS 4, NIST SP 800-53 R5, CIS Azure Foundations); Defender also assesses AWS accounts	P0 schema; Defender pilot
Microsoft Entra ID + Microsoft Teams + Entra ID Governance	Roles and separation of duties; adaptive-card approvals; multi-stage access packages	P0 roles; Teams S; Governance pilot
GitHub Actions environment protection rules + GitHub Advanced Security	Human-gated deployment of the Bicep PR; template and secret scanning	S
Azure Deployment Environments; Microsoft Fabric / Power BI; Microsoft Purview	Real governed provisioning from a catalog; readiness dashboard; sensitivity labels choose the rule pack	Pilot

13 / 14 Build Plan (2h30) & Key Risks

MILESTONES FROM SOW APPROVAL

- T+0:15 Repo scaffolded by the Copilot coding agent from one issue; rule schema in copilot-instructions (lead, architect).
- T+0:45 Rule engine and 8 rules with control IDs; unit-tested with the three scenarios (architect, governance).
- T+1:15 Portal, role-based approvals, audit log and status page (app/DevOps).
- T+1:45 Azure AI Foundry agent: risk memo and grounded explainer, cached fallbacks (AI specialist).
- T+2:10 Simulated deployment from the Bicep template; counters; all three scenarios pass end to end.
- T+2:30 Freeze, measurements into this SOW, pitch rehearsal. Stretch items only if every P0 scenario passed.

RISKS AND MITIGATIONS

- **The figures cover a wider process than we assume:** present them as reported, confirm with Maria; the prototype measures its own flow (lead).
- **Illustrative rules taken for Mastercard policy:** every rule cites a public source; stated in the SOW and the demo (governance).
- **Agent drafts taken for decisions:** read-only tools, labelled drafts, only Entra-role humans approve (AI specialist).
- **Azure provisioning or API delays in 2h30:** local store and cached agent answers as fallbacks; scenarios run offline (app/DevOps).
- **Scope creep:** one template, 8 rules, 3 scenarios; stretch only after P0 passes (lead).

15 Security, Privacy & Responsible AI

Synthetic requests only; no Mastercard data, credentials or system access. Least privilege and separation of duties across requester, security approver and platform approver. Pass or fail comes from versioned rules, never from a model; only humans approve; only approved requests reach execution. The agent reads only the request and rule results, refuses questions outside that scope and cites the rule so a human can check; model output can still be wrong. The audit log is append-only and exportable; rules cannot be edited from the portal. In a pilot, Mastercard security owns the catalogue. Rules apply the same way to every request; no personal data is collected.

16 / 17 Decision Requested & Managing Director Comments

We ask the MD to approve: (1) the problem framing: a long, serial, people-dependent compliance chain between an approved idea and a development-ready environment (reported 6–8 months, ~12 handoffs); (2) the direction: a control plane where agents prepare, rules decide, humans approve in Teams and GitHub enforces the gate; (3) the scope in Section 07; (4) the 2h30 build plan and resourcing; (5) permission to proceed to Build.

☐ APPROVE: PROCEED TO BUILD	☐ APPROVE WITH CHANGES: PROCEED AFTER LISTED REVISIONS	☐ REVISE AND RESUBMIT
MD comments:	Managing Director: _____ Date / Time: _____	Team Lead (Garden State): _____